

1. Análisis y planificación del pentest

Objetivo del pentest

El objetivo principal de realizar esta prueba de penetración no se limita a un escaneo técnico, sino que busca proporcionar a Aurora Market una visión clara y realista sobre su postura de seguridad actual frente a posibles ciberataques. Al realizar esta evaluación, se busca conocer si los controles de seguridad implementados en la plataforma web son suficientes para proteger la integridad, confidencialidad y disponibilidad de la información de sus clientes y operaciones comerciales. El valor fundamental de este ejercicio para Aurora Market radica en la prevención: identificar proactivamente vectores de ataque antes de que un actor malicioso los aproveche, mitigando así riesgos financieros, pérdida de reputación y asegurando la continuidad del negocio en un entorno digital cada vez más hostil.

2. Alcance

Sí se evaluará

1. Evaluación exclusiva de la dirección IP pública y el dominio web asignados formalmente por Aurora Market.
2. Mapeo de red y servicios: Escaneo de puertos abiertos y detección de servicios asociados al host con el fin de identificar puertos expuestos e interfaces vulnerables.
3. Auditoría de la plataforma web: Análisis de vulnerabilidades en la aplicación web (encabezados de seguridad, formularios, parámetros y configuraciones).

Fuera del alcance

1. Redes sociales corporativas: No se realizará ningún tipo de ataque, suplantación o scraping no autorizado en perfiles de redes sociales de Aurora Market.
2. Servidores de correo e ingeniería social: Quedan excluidos los ataques de phishing, spear-phishing o recolección de credenciales mediante engaño a los empleados.
3. Dispositivos de empleados: Queda estrictamente prohibido intentar comprometer estaciones de trabajo, laptops o móviles personales del personal.
4. Infraestructura de terceros: No se evaluarán servicios alojados por proveedores externos o plataformas SaaS que no pertenezcan al dominio directo de Aurora Market.
5. Ataques de Denegación de Servicio (DoS/DDoS): Se prohíbe cualquier prueba de estrés o saturación de ancho de banda para asegurar la constante disponibilidad del sitio para los clientes.

3. Autorización y condiciones

Permisos requeridos

- Carta de autorización de pruebas (Rules of Engagement - RoE): Documento firmado por la gerencia de Aurora Market que autoriza legalmente el análisis de seguridad sobre la IP designada.
- Aprobación del instrumental técnico: Acuerdos para utilizar exclusivamente herramientas de auditoría previamente validadas por el cliente (p. ej., Nmap, OWASP ZAP, Wireshark, SearchSploit).
- Explotación ética y orientada a soluciones: Autorización para comprobar la viabilidad de la vulnerabilidad con el compromiso de proponer medidas de mitigación directas.
- Entorno de prueba controlado: Permiso para ejecutar el conjunto de herramientas desde un sistema operativo dedicado y seguro (Kali Linux virtualizado en VirtualBox).

Condiciones acordadas

- Preservación de la integridad de los datos: Prohibición absoluta de alterar, borrar o corromper bases de datos o registros del sistema durante el análisis.
- Restricción estricta del perímetro: No se rebasarán los límites de la plataforma web autorizada bajo ninguna circunstancia.
- Acuerdo de confidencialidad (NDA): Garantía mediante contrato de que toda información recopilada, así como las vulnerabilidades detectadas, serán tratadas con estricta reserva confidencial.
- Plan de reporte y comunicación inmediata: Compromiso de notificar de inmediato si se detecta un hallazgo crítico (que ponga en riesgo inminente el sistema) y entrega de un informe final con estrategias claras de mitigación y el detalle de cualquier incidente observado.

4. Tipo de pentest

Tipo de pentest elegido: Gray-Box



Justificación

La elección del modelo de Caja Gris responde a un equilibrio estratégico entre la eficiencia del tiempo de evaluación, el realismo de las pruebas y las restricciones operativas planteadas por Aurora Market:

- Eficiencia de costos y tiempo frente a Caja Negra (Black-Box): En un enfoque a ciegas, el equipo dedicaría una porción considerable del tiempo acordado únicamente en descubrir datos básicos de infraestructura. Al contar con información parcial previa (como la IP pública autorizada y el dominio objetivo), se suprimen pasos redundantes de reconocimiento pasivo y se enfoca el esfuerzo técnico directamente en auditar los servicios y la aplicación web expuesta.
- Resguardo de confidencialidad frente a Caja Blanca (White-Box): Un análisis de Caja Blanca requeriría acceso total al código fuente, diagramas de arquitectura interna y credenciales administrativas de red. Por solicitud explícita del cliente, no se brindan detalles internos para mantener la privacidad del entorno corporativo, delimitando el alcance estrictamente al perímetro web sin comprometer la estructura interna del negocio.
- Simulación realista de vectores de amenaza: La Caja Gris replica con precisión el escenario de un atacante que posee cierto grado de conocimiento del objetivo. Esto abarca desde un cibercriminal que ha recolectado datos previos en fuentes abiertas (OSINT) o filtraciones de credenciales, hasta la amenaza potencial de un usuario autenticado de bajo nivel o un socio comercial que intenta manipular parámetros para escalar privilegios o acceder de forma no autorizada a la plataforma de Aurora Market.

5. Planificación

OBJETIVOS: Analisis de ip autorizada para obtener analisis de seguridad e identificar amenazas de seguridad.

ALCANCE: IP autorizada para análisis, puertos y servicios asociados al host.

PERMISOS Y CONDICIONES: herramientas de escaneo y auditoria (wireshark, searchsploit)

METODOLOGÍA A UTILIZAR: Prueba de penetración de caja gris sobre infraestructura y servicios de red.

RECOPIACIÓN DE INFORMACIÓN PREVIA: Para esta fase, se utilizará un enfoque híbrido que combinará fuentes abiertas (OSINT) y métodos activos de recopilación. Inicialmente, se recurrirá a OSINT (como Google Dorks, Shodan o recolección de metadatos)

RECURSOS NECESARIOS: Virtual box, kali linux, Nmap, SeachSploit, Wireshark).

PROGRAMACIÓN DEL PENTEST: Se propone realizar el pentest en una ventana de mantenimiento o de baja demanda de tráfico, específicamente entre las 2:00 a.m. y las 4:00 a.m.

6. Fases del pentest

1.RECONOCIMIENTO: En esta fase, la meta es construir un perfil completo de la superficie de ataque. Se comenzará recopilando información sobre Aurora Market mediante OSINT para no levantar sospechas. Luego, se procederá a identificar los posibles puntos de entrada mediante un análisis de puertos utilizando Nmap. Se buscará conocer qué puertos están abiertos (por ejemplo, 80 para HTTP, 443 para HTTPS, o puertos de bases de datos expuestos) y qué versiones de servicios se están ejecutando. Esta información es vital antes de avanzar, ya que determina qué tipo de vulnerabilidades podrían existir en esos servicios específicos.

2. ANÁLISIS DE VULNERABILIDADES: Una vez identificados los servicios, se utilizará OWASP ZAP (enfocado en la plataforma web) y los scripts de vulnerabilidad de Nmap (NSE). La información que se busca obtener son fallas de seguridad conocidas (CVEs), malas configuraciones (como falta de cabeceras de seguridad), o formularios web susceptibles a inyecciones (SQLi o XSS). El propósito de esta fase dentro de la evaluación es correlacionar los servicios descubiertos en el reconocimiento con debilidades reales documentadas, generando un mapa claro de los puntos débiles a comprobar.

3.EXPLOTAÇÃO: En esta etapa, se buscará determinar el impacto real de las vulnerabilidades descubiertas. Utilizando herramientas como SearchSploit u otros frameworks desde Kali Linux, se intentará ganar acceso al sistema explotando las fallas de manera ética y controlada. El abordaje respetará estrictamente las condiciones del cliente: no se corromperán datos y la prueba se limitará al alcance web autorizado, buscando únicamente confirmar si un atacante real podría comprometer el sistema.

4. POST- EXPLOTACIÓN: Asumiendo que se lograra vulnerar la plataforma web, esta fase busca responder: "¿Qué más puede hacer un atacante desde aquí?". Se analizará el nivel de privilegios obtenidos y se evaluará si es posible realizar movimientos laterales hacia otros segmentos de la red interna de Aurora Market o si se puede acceder a bases de datos con información sensible de los clientes, todo esto sin extraer ni alterar dicha información

5. INFORME: Finalmente, se consolidará toda la evidencia fotográfica y los datos recopilados en un reporte ejecutivo y técnico. El abordaje consistirá en no solo listar las vulnerabilidades (hallazgos), sino explicar cómo se replicó el ataque y, lo más importante, proporcionar estrategias de remediación concretas para que Aurora Market pueda neutralizar estas amenazas antes de que sean explotadas maliciosamente.

7. Investigación

METODOLOGÍA ELEGIDA:

Para el desarrollo de este proyecto se ha seleccionado la metodología de Pruebas de Penetración de Caja Gris (Gray-Box Pentesting). Esta metodología se estructura en un ciclo operativo de 5 fases secuenciales: Reconocimiento, Análisis de vulnerabilidades, Explotación, Post-explotación e Informe.

¿PORQUÉ SERÍA ÚTIL PARA ESTE PROYECTO?

- Eficiencia de tiempo y recursos: Al proporcionar el cliente cierta información previa (como la IP autorizada y el dominio), se descarta un enfoque a ciegas (Black-Box). Esto evita gastar tiempo excesivo en el descubrimiento básico de infraestructura y permite enfocar el esfuerzo técnico directamente en la detección profunda de fallas y análisis de puertos.
- Simulación realista de amenazas modernas: La Caja Gris equilibra la perspectiva externa de un atacante con la de un actor que ha conseguido cierto nivel de acceso inicial (por ejemplo, un ciberdelincuente que obtuvo datos mediante OSINT, un usuario autenticado con privilegios bajos o un socio comercial). Esto permite evaluar el impacto real si un vector de entrada básico resulta comprometido.
- Alineación con marcos de referencia éticos: Se sigue una aproximación alineada con estándares como la Guía de Pruebas de Seguridad Web de OWASP (WSTG). Las pruebas se realizan de manera ética, no invasiva y documentada paso a paso con evidencia fotográfica, garantizando que Aurora Market reciba un reporte técnico accionable sin poner en riesgo la continuidad de sus servicios.